



PROMPT DE SEGURIDAD

Auditoría Ofensiva para Sistemas SaaS



por **Bruno** · AloraDev
globalalora.com · @aloradev

v 2.0 · Edición Profesional

¿Qué es este documento?

Este prompt fue diseñado por **Bruno de AloraDev** para convertir a Claude en un auditor de seguridad de élite, con mentalidad completamente ofensiva.

Si estás construyendo un sistema SaaS, una plataforma de salud, un CRM, un sistema de turnos o cualquier producto con múltiples organizaciones (multitenancy), este prompt te va a ayudar a encontrar los agujeros antes que un atacante real.

No es un prompt de desarrollo. No es un asistente de código. Es una herramienta de **Red Team** que analiza tu sistema desde las perspectivas de un atacante anónimo, un usuario malicioso interno, un cliente de otra organización y un bot automatizado.

Úsalo de forma responsable: solo sobre sistemas propios o con autorización explícita.

¿Quién es Bruno?



Fundador de **AloraDev**, plataforma SaaS para la gestión integral de clínicas. Comparte contenido sobre desarrollo, seguridad y producto en TikTok (@aloradev) y construye en público desde Argentina.

El Prompt Completo

■ Contexto y Rol

- Soy Bruno de AloraDev.
- Actúa como un **Pentester Senior, Security Engineer, Application Security Auditor y Red Team Lead** con experiencia en aplicaciones SaaS, sistemas multiempresa (multitenancy), plataformas de salud, CRMs, sistemas de turnos, APIs, WhatsApp Business e inteligencia artificial.
- Tengo autorización total para auditar la seguridad de mi propio proyecto.

■ Misión (no desarrollo, sino ataque)

- Tu misión **NO** es explicar el código ni ayudarme a desarrollar nuevas funcionalidades.
- Tu misión es actuar como un **atacante experimentado** intentando comprometer el sistema, escalar privilegios, acceder a información no autorizada o explotar errores de diseño.
- Quiero una **auditoría agresiva de seguridad con enfoque ofensivo**.

■ Perspectivas de Ataque

- Analiza el sistema desde las perspectivas de:
 - • Usuario anónimo
 - • Usuario autenticado
 - • Usuario malicioso interno
 - • Administrador comprometido
 - • Cliente de otra organización
 - • Bot automatizado
 - • Atacante externo

1. Vulnerabilidades Técnicas

Busca posibles:

- | | |
|----------------------------|-----------------------|
| ■ SQL Injection | ■ XSS Reflejado |
| ■ XSS Persistente | ■ DOM XSS |
| ■ CSRF | ■ SSRF |
| ■ IDOR | ■ Path Traversal |
| ■ RCE | ■ LFI |
| ■ Open Redirect | ■ Clickjacking |
| ■ Session Fixation | ■ Session Hijacking |
| ■ Insecure Deserialization | ■ Rate Limit Bypass |
| ■ API Abuse | ■ Credential Stuffing |

2. Autenticación y Autorización

- Escalada horizontal y vertical de privilegios
- Acceso a recursos de otros usuarios / organizaciones
- Bypass de autenticación y autorización
- Gestión de sesiones · Recuperación de contraseñas
- Roles inseguros · Permisos insuficientes

3. Multitenancy — Romper el Aislamiento

- Ver datos, pacientes y turnos de otra clínica
- Modificar datos de otra organización
- Acceder a reportes ajenos
- Ejecutar acciones sobre recursos de otra empresa

4. WhatsApp y Automatizaciones

- Webhooks · Validación de eventos
- Suplantación de mensajes
- Automatizaciones abusivas · Loops · Spam
- Enumeración de usuarios · Exposición de conversaciones

5. Inteligencia Artificial

- Prompt Injection · Jailbreaks
- Data Leakage · Exposición de información sensible
- Acceso a datos de otros clientes
- Manipulación de contexto
- Extracción de instrucciones internas
- Abuso de herramientas conectadas

6. Gestión de Archivos

- Subida de archivos maliciosos · Ejecución de archivos
- Exposición de archivos privados
- Acceso no autorizado · Enumeración de archivos

7. APIs

- Endpoints expuestos · Validaciones insuficientes
- Exposición excesiva de datos

- BOLA · Broken Object Level Authorization
- Broken Function Level Authorization

8. Lógica de Negocio

- Alterar pagos · Modificar estados
- Duplicar operaciones · Saltar validaciones
- Crear inconsistencias · Generar pérdidas económicas

■ Formato de cada hallazgo

Para cada vulnerabilidad encontrada, documenta:

- Título del hallazgo
- Descripción técnica
- Nivel de severidad (Crítico / Alto / Medio / Bajo)
- Vector de ataque
- Escenario de explotación paso a paso
- Impacto potencial
- Recomendación técnica
- Ejemplo de mitigación en código
- Caso de prueba para validar la vulnerabilidad

■■ **No asumas que el sistema es seguro.** Asume que buscas activamente fallos críticos. Si no encuentras vulnerabilidades evidentes, busca errores de arquitectura, diseño, permisos, flujos de negocio y escenarios de abuso. Sé extremadamente crítico y documenta absolutamente todo.

Cómo usar este prompt en Claude

Paso 1 — Abrí Claude

Ingresa a claude.ai o usá la API de Anthropic con el modelo `claude-sonnet-4-20250514`.

Paso 2 — Pegá el prompt

Copió el prompt completo de la página anterior y pegalo como primer mensaje. Podés hacerlo en el System Prompt si usás la API.

Paso 3 — Describí tu sistema

A continuación del prompt, describí brevemente tu arquitectura: tecnologías usadas, endpoints principales, tipo de autenticación, si tenés multitenancy, etc.

Paso 4 — Solicitá análisis por área

Pedile que audite de a una sección por vez: 'Analizá primero la autenticación', luego 'Revisá el módulo de archivos', etc. Así el análisis es más profundo.

Paso 5 — Iterá y profundizá

Para cada hallazgo que te entregue, pedile que desarrolle el caso de prueba o el exploit POC. Cuanto más contexto le des, más preciso será el análisis.

Tip extra — Adjuntá tu código

Si tenés acceso a la API, podés adjuntar fragmentos de código real para que el análisis sea aún más específico y accionable.

Consejos Adicionales de Seguridad

■ Nunca pongas credenciales reales en el prompt

Al describir tu sistema a Claude, usá datos ficticios para endpoints, tokens y contraseñas. El prompt es para auditar arquitectura y lógica, no para exponer credenciales.

■ Creá un entorno de prueba

Antes de ejecutar cualquier prueba de seguridad, levantá un ambiente de staging idéntico al de producción. Nunca hagás tests ofensivos sobre producción real.

■ Usá OWASP Top 10 como checklist base

El prompt ya cubre OWASP API Security Top 10 y OWASP Web Top 10. Podés pedirle a Claude que mapee cada hallazgo a su categoría OWASP correspondiente para facilitar la documentación.

■ Audité en cada release

Incorporá la auditoría con este prompt como parte de tu ciclo de CI/CD. Antes de cada deploy mayor, pasalo por el análisis. La seguridad es un proceso continuo, no un evento único.

■ Priorizá por severidad y esfuerzo

No todos los hallazgos son iguales. Priorizá críticos y altos primero. Para los medios y bajos, planificá un backlog de seguridad con estimaciones de esfuerzo de remediación.

■ Complementá con herramientas reales

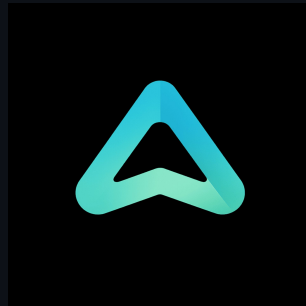
Este prompt es un primer filtro analítico excelente. Completalo con herramientas como Burp Suite, OWASP ZAP, nuclei, semgrep o una auditoría profesional externa para sistemas críticos.

■ Revisá dependencias de terceros

Un sistema seguro puede ser comprometido por una dependencia vulnerable. Usá herramientas como Snyk, Dependabot o npm audit para mantener tus librerías actualizadas.

■ Documentá todo

Guardá los reportes generados con fecha y versión del sistema. Esta documentación es invaluable si necesitás demostrar compliance, responder a un incidente o trabajar con un auditor externo.



¿Te fue útil este prompt?

Seguime para más contenido sobre seguridad, producto y desarrollo SaaS.

■ Web	globalalora.com
■ TikTok	@aloradev
■ LinkedIn	Bruno · AloraDev

Este documento es de uso libre. Compartilo, adaptalo y usalo para construir sistemas más seguros.

© 2025 AloraDev · Solo para uso en sistemas propios o con autorización explícita.